

Taller Extendido: Diseño de un Esquema de Control de Acceso (Modelo AAA)

Materia: Fundamentos de Seguridad de la Información Duración: 40 - 50 minutos

1. Contexto Empresarial: "MediTech Solutions"

MediTech Solutions es una organización proveedora de servicios de salud digital. Debido al aumento de ciberataques contra el sector salud, la junta directiva ha decidido rediseñar su arquitectura de seguridad basándose en el estándar AAA (Authentication, Authorization, Accounting).

Activos Críticos de Información:

1. Historias Clínicas (DB): Base de datos con diagnósticos, tratamientos y recetas (Nivel de confidencialidad: Muy Alto).
2. Servidor de Facturación y Nómina: Gestión de pagos a proveedores, salarios de empleados y procesamiento de tarjetas de crédito.
3. Logs de Auditoría (Syslog): Registros inmutables de actividad de red y accesos a servidores.
4. Módulo de Agendamiento: Calendario operativo para la gestión de citas y disponibilidad de especialistas.

Perfiles de Usuario (Sujetos):

- **Médicos Especialistas:** Personal que requiere acceso a datos clínicos para diagnóstico.
- **Administrativos de Recepción:** Encargados de la logística de citas y cobros básicos.
- **Pacientes:** Usuarios finales que acceden vía web/móvil para consultar sus resultados.
- **Audidores Externos de TI:** Consultores que verifican el cumplimiento de normas de seguridad sin interferir en la operación.

2. Actividades del Taller

Fase A: Autenticación Robusta

El sistema actual solo usa usuario y contraseña. Ustedes deben proponer un esquema de Autenticación de Múltiple Factor (MFA) diferenciado por riesgo:

1. Para Administrativos: Propongan dos factores económicos pero efectivos.
2. Para Médicos (Acceso a Historias Clínicas): Propongan un esquema que combine Algo que sabe y Algo que es (Biometría). Justifiquen por qué la biometría es crítica en este caso.
3. Gestión de Fallos: ¿Cuántos intentos fallidos permitirán antes de bloquear la cuenta y qué método de recuperación proponen para no afectar la atención de emergencias médicas?

Fase B: Autorización y Matriz de Control de Acceso

Siguiendo el modelo RBAC (Role-Based Access Control), completen la matriz de permisos. Convenciones: (L) Leer, (E) Escribir/Editar, (B) Borrar, (N) Ningún acceso.

Recurso / Rol	Médicos	Administrativos	Pacientes	Audidores
Historias Clínicas				
Facturación / Pagos				
Logs de Seguridad				
Agenda de Citas				

Pregunta de diseño: El Administrativo necesita saber *con quién* tiene cita el paciente, pero no *por qué* (diagnóstico). ¿Cómo aplicarían el Principio de Mínimo Privilegio aquí?

Fase C: Accounting, Auditoría y SIEM

Para garantizar la trazabilidad (Accounting), la empresa implementará un SIEM.

1. Eventos Críticos: Listen 4 eventos específicos que el SIEM debe alertar en tiempo real (Ejemplo: *Intento de borrado de logs*).
2. Escenario de Incidente: Un médico intenta acceder a la base de datos de facturación un domingo a las 2:00 AM.
 - ¿Qué componente del modelo AAA bloquea la acción?
 - ¿Qué información debe contener el registro de *Accounting* para que sea útil en una investigación legal posterior?

Fase D: Análisis de Modelos

Basado en las diapositivas de la clase (pág. 18), comparen brevemente:

- ¿Por qué en este escenario médico el modelo MAC (Mandatory Access Control) podría ser más seguro que el modelo DAC (Discretionary Access Control)?

3. Socialización y Conclusión

Cada grupo debe preparar un breve párrafo donde explique:

1. Su estrategia de MFA para evitar el robo de identidad médica.
2. Una situación donde el sistema de *Accounting* salvó a la empresa de una demanda legal.

4. Criterios de Evaluación

- Profundidad Técnica: Uso correcto de términos como MFA, RBAC, SIEM y Trazabilidad.
- Coherencia: La matriz de acceso no debe violar la privacidad del paciente.
- Resolución de Problemas: Propuestas lógicas para la recuperación de cuentas y manejo